INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Governance, Compliance, and Risk Engineering Cohort B 2025 Training Program

INCIDENT RESPONSE PLANNING ASSIGNMENT

GRC205 | Incident Management and Business Continuity | Week 20

Student Information

Full Name	SAMUEL ADEOLUWA OKUNRIBIDO
Student ID	2025/GCR/12878
Batch	Batch B2025
Course Code	GRC205
Course Title	Incident Management and Business Continuity
Date Completed	17th October 2026
Time Started / Time Ended	19th October 2026
Total Time Spent	30 hours

Lab Details

Lab Title	Incident Management and Business Continuity
Expected Duration	12 hours
Deadline	Tuesday, 20 October 2026, 11:59 PM WAT

Submitted by

SAMUEL ADEOLUWA OKUNRIBIDO

Student ID: 2025/GCR/12878

Email: gcr2512878@students.icdfa.edu.ng

Scenario: Northbridge Skills Institute - Suspected Ransomware Incident

Role: Incident Response Lead

Executive Summary

This laboratory assessment required the author to assume the role of Incident Response Lead for Northbridge Skills Institute during a suspected ransomware incident affecting a finance workstation (FIN-PC07), the shared file server (FS01), the learning portal (LMS01), and associated backup systems. The exercise commenced at 08:45 WAT on Day 0, approximately two hours before a scheduled online examination for 100 learners.

Evidence E01-E08 was analyzed to construct a timeline distinguishing confirmed observations from working hypotheses. The incident was classified as ransomware with potential credential compromise and possible data staging, and was rated Critical on the basis of the imminent examination deadline, confirmed encryption of shared folders, anomalous privileged activity by the svc_backup account, and incomplete visibility of scope and recover-ability.

A full incident response plan was developed, including policy elements, a seven-role CSIRT structure, a RACI matrix covering eight core activities, and four prioritized readiness improvements. A sequenced playbook for the first 60 minutes and the remainder of the first 24 hours was produced, together with an evidence register, justification of two difficult operational decisions, and formal recovery acceptance criteria. Communication and escalation arrangements were defined for six stakeholder groups,

supported by draft executive and learner notices. A 60-minute tabletop exercise tested the plan against five injects (including one original), generating a decision log and five measurable improvement actions. Finally, lessons from an illustrative healthcare ransomware case were transferred to the Northbridge plan, and one restoration decision was revised in light of the tabletop results.
The assessment demonstrates the practical application of NIST SP 800-61 Revision 3 principles within a constrained organizational environment and highlights the critical importance of validated offline backups, clear decision authority, and resilient communication channels.

Lab Objectives

1. Classify a suspected ransomware incident using supplied evidence, distinguishing confirmed facts from hypotheses and assessing severity against defined operational criteria.
2. Develop a usable incident response plan containing mission, scope, declaration and escalation rules, authority to isolate systems, documentation requirements, and integration with business continuity.
3. Define a realistic Computer Security Incident Response Team (CSIRT) structure and a RACI matrix for eight core response activities.
4. Construct a time-sequenced response playbook covering the first 60 minutes and the remainder of the first 24 hours, addressing containment, evidence preservation, eradication and recovery.
5. Design and execute a 60-minute tabletop exercise that tests decision-making under pressure, including five injects, a decision log, and a prioritised improvement plan.
6. Analyze an illustrative healthcare ransomware case, extract transferable strengths, and critically revise one decision in the Northbridge plan.

Tools and Resources Used

Category	Resource
Framework guidance	NIST SP 800-61 Revision 3 (2025) - Incident Response Recommendations and Considerations for Cybersecurity Risk Management (CSF 2.0 Community Profile)
Practical guidance	CISA #StopRansomware Guide
Course materials	ICDFA GRC105 Week 20 Teaching Deck (slides 1-18), including the illustrative healthcare ransomware case on slide 16
Scenario data	Supplied evidence pack E01-E08 for Northbridge Skills Institute
Legal reference	Nigeria Data Protection Act 2023 (for notification obligation analysis)
Analytical methods	Timeline construction, CIA triad assessment, RACI matrix design, playbook sequencing, tabletop inject design and decision logging
Documentation	Structured tables for severity criteria, asset impact, communication matrix, escalation rules, evidence register, decision log and improvement plan

No live technical tools (forensic imaging software, SIEM platforms or live systems) were required; the assessment was scenario-based and documentary.

Analysis and Findings

Incident classification

The combination of a malicious attachment on FIN-PC07 (E01), anomalous cloud sign-in (E02), out-of-hours privileged logons by svc_backup (E03), a 1.2 GB outbound transfer (E04), confirmed .locked files and ransom note on FS01 (E06), and functional unavailability of the learning portal (E07) supported classification as ransomware with potential credential compromise and possible data staging. Severity was assessed as Critical because of the two-hour examination window, confirmed encryption of shared teaching materials, and uncertainty surrounding backup integrity.

Response planning

The plan established clear declaration criteria, standing isolation authority, joint accountability for

restoration approval (Incident Response Lead + Business Owner), and mandatory escalation paths for Critical incidents and personal-data exposure. The RACI matrix assigned exactly one Accountable role per activity while permitting combined A/R where operational acceptance was required.

Operational response

The playbook prioritised isolation of FIN-PC07 without powering it off (to preserve volatile memory), immediate credential rotation for the finance officer and svc_backup accounts, restriction of access to FS01 and BAK01, and protection of the offline Day -3 backup. Two difficult trade-offs were explicitly justified: network isolation versus evidence preservation, and limited examination contingency versus the risk of restoring from an unvalidated backup.

Tabletop results

All five success criteria were met in simulation. Management pressure to reopen the portal was resisted; the attacker's data-exfiltration claim was treated as unconfirmed and escalated to Legal; the failed network-backup restoration led to formal abandonment of that source; media enquiries were controlled; and a staff-intimidation inject triggered welfare and evidence-collection actions. Five improvement actions were identified, with the highest priority assigned to establishment of an isolated recovery environment for backup validation.

Case-study transfer

The healthcare case demonstrated the value of rapid isolation, tested offline backups, and structured communication. These practices were mapped onto Northbridge's joint restoration-approval gate and the insistence on validated offline media before any learner-accessible restoration.

Main Challenges

1. **Time pressure versus validation** - The examination scheduled for 11:00 created intense pressure to restore service before the offline backup could be fully validated.
2. **Incomplete evidence** - Absence of malware-family identification, MFA status, content of the 1.2 GB transfer, and server EDR coverage forced decisions under significant uncertainty.
3. **Small team capacity** - With only three IT staff and one security analyst, the CSIRT required clear escalation routes to external forensic and legal support.
4. **Untrusted communication channels** - The incident contact list resided solely on FS01 and corporate email trustworthiness was unverified, necessitating immediate reliance on out-of-band channels.
5. **Backup integrity** - Network backups were neither immutable nor recently tested; the only known offline backup dated from Day -3 and had never been restoration-tested within the preceding 90 days.

Conclusions

The assessment confirms that effective incident response in a resource-constrained education environment depends on three foundational elements:

1. Pre-defined decision authority and escalation paths that survive the loss of primary systems;
2. Validated, offline or immutable backups that can be restored under controlled conditions; and
3. Disciplined communication that separates operational notices from formal breach notifications.

The tabletop exercise demonstrated that the plan's restoration-approval gate and Legal escalation rules held under pressure, but also revealed residual weaknesses in recovery environment readiness and media-handling templates.

The revised decision has no learner-accessible restoration until documented sample validation of the offline backup is complete which must directly addresses the most significant operational risk identified during the exercise.

Overall, the laboratory work illustrates the practical application of NIST SP 800-61 Revision 3 within the CSF 2.0 functions of Detect, Respond and Recover, while embedding preparation activities (Govern, Identify, Protect) and continuous improvement.

Recommendations

1. **Immediate (0 - 14 days)** - Establish and test an isolated recovery environment; complete the first successful sample restoration from the offline Day -3 backup; update and verify the offline incident contact list.
2. **Short-term (15 - 30 days)** - Implement immutable or air-gapped backup capability with quarterly restoration testing; publish a pre-approved media holding-statement template reviewed by Legal.
3. **Medium-term (30 - 90 days)** - Conduct a full technical tabletop that includes live log review and simulated forensic acquisition; deliver role-specific refresher training to all CSIRT members; develop a staff-welfare protocol for individuals targeted by attackers.
4. **Ongoing** - Schedule annual tabletop exercises linked to business-continuity testing; review the incident response plan after every Critical or High incident and at least once every twelve months; ensure server EDR coverage is extended and MFA is enforced on all privileged and service accounts.

Task 1 - Incident Classification and Initial Assessment.

1.1 Incident Timeline (E01-E08)

The following timeline separates confirmed observations from working hypotheses and unresolved questions. All times are West Africa Time (WAT). Evidence identifiers are cited directly.

Time (WAT)	Confirmed Observation	Working Hypothesis	Unresolved Questions / Alternatives
Day -1, 16:40 (E01)	Finance officer opened an unexpected payroll attachment on FIN-PC07. Mail record confirms receipt and opening.	Attachment contained a malicious payload that executed and established initial access.	Alternative 1: Legitimate (though unexpected) payroll file; no code execution occurred. Alternative 2: Attachment was malicious but the payload failed to run or was blocked. Execution remains unverified.
Day 0, 01:15 (E02)	Finance officer account signed in to Microsoft 365 from an unfamiliar IP address and new device.	Credentials or session token were compromised after the attachment was opened, enabling cloud access.	MFA status unknown. User may have legitimately travelled or used a new device. Compromised credentials versus session hijacking cannot yet be distinguished.
Day 0, 01:35 (E03)	svc_backup performed remote administrator logons to FS01 and BAK01 outside its normal schedule.	Attacker obtained or reused the svc_backup credentials (or token) to move laterally and access the file server and backup repository.	Legitimate (but unscheduled) administrative activity by IT staff. Credentials may have been stolen earlier or the account misused without full password compromise.
Day 0, 01:50 (E04)	FIN-PC07 uploaded 1.2 GB over HTTPS to unfamiliar cloud storage.	Data staging or exfiltration of files from FIN-PC07 (and possibly mapped drives) prior to encryption.	Upload could be legitimate large-file transfer by the finance officer. Content of the transfer is unknown; volume alone does not prove personal data was taken.
Day 0, 02:00 (E05)	Backup console reported successful FS01 and LMS01 jobs.	Jobs may have completed on already-compromised data or the backup infrastructure itself may have been accessed by the attacker.	Jobs succeeded and contain clean data. Recoverability and freedom from compromise have not been tested.
Day 0, 08:30 (E06)	Mass file changes observed on FIN-PC07. FS01 shared folders contain .locked files and a ransom note.	Ransomware has encrypted files on the finance workstation and the shared file server. Malware family remains unconfirmed.	Partial encryption only; some shares may remain intact. Ransom note could be a false-flag or secondary payload.

Day 0, 08:40 (E07)	Portal login page loads but learners cannot open materials or submit assessments.	LMS01 depends on files stored on FS01; encryption of those files has rendered the learning portal effectively unavailable.	LMS01 itself may be encrypted or only the dependent shares are affected. Scope of damage to the LMS server remains unknown.
Day 0, 08:45 (E08)	Incident contact list on FS01 is inaccessible. Staff telephones remain available. Trustworthiness of corporate email is unverified.	Attackers may have targeted or encrypted operational documentation as part of the same campaign.	Contact list was simply never stored in a resilient location; no deliberate targeting of the list occurred.

Assumptions explicitly labelled:

- The ransomware family is currently unconfirmed (E06).
- No definitive proof of personal-data exfiltration exists; the 1.2 GB transfer (E04) is treated as potential rather than confirmed theft.
- The last offline backup is presumed intact until restoration testing proves otherwise.

1.2 Incident Classification and Severity Assessment

Severity definitions applied by Northbridge Skills Institute:

Severity	Criteria
Critical	Confirmed or highly probable impact on core teaching or examination operations within the next 4 hours; confirmed or probable compromise of systems holding regulated personal data; evidence of active lateral movement or backup compromise; or any combination that threatens immediate regulatory or reputational harm.
High	Significant disruption to business processes expected within 24 hours; potential exposure of personal data; incomplete visibility of scope; or material risk to recovery capability.
Medium	Limited operational impact confined to non-critical systems; no confirmed data exposure; recovery path is clear and tested.
Low	Isolated workstation or user-level event with no lateral movement and no impact on shared services or examinations.

Selected classification: Incident type - Ransomware (with potential credential compromise and possible data staging). Initial severity - **Critical**.

Justification:

- Operational impact: An online examination for 100 learners is scheduled for 11:00 (approximately 2 hours 15 minutes from the moment of takeover). The learning portal is already unavailable for material access and assessment submission (E07).
- Affected data: FS01 holds learner contact details, admission documents, assessment records and finance files. Encryption of shared folders is confirmed (E06).
- Uncertainty: Backup recoverability is untested (E05); the svc_backup account shows anomalous activity (E03); a large outbound transfer occurred (E04); and EDR coverage on servers is incomplete. These factors elevate residual risk above High.

1.3 Confirmed and Potentially Affected Assets - CIA Assessment and Response Priorities

Asset	Confidentiality	Integrity	Availability	Priority Rationale
FIN-PC07	Potentially compromised (possible staging)	Confirmed encryption	Confirmed impact	Isolate immediately to prevent further spread.
FS01 (shared file server)	Potentially compromised	Confirmed encryption of shared folders	Confirmed impact on LMS materials	Highest operational priority - examination materials depend on it.
LMS01 (learning portal)	Unknown	Unknown	Confirmed functional impact	Dependent on FS01; treat as affected until proven otherwise.

BAK01 (network backup)	Unknown (svc_backup activity)	Unknown	Potentially compromised	Preserve offline backup; treat network backups as untrusted until validated.
Microsoft 365 (identity & email)	Possible credential compromise	Unknown	Available but trustworthiness unverified	Force credential reset and session revocation for finance officer and svc_backup.
Offline backup (Day -3)	Presumed intact	Presumed intact	Available	Primary recovery source pending validation.

Response priorities (ordered):

1. Contain FIN-PC07 and protect remaining clean systems.
2. Secure privileged accounts (svc_backup and finance officer).
3. Preserve the offline backup and restrict further access to BAK01.
4. Determine whether a safe subset of examination materials can be restored or delivered by alternative means before 11:00.
5. Establish scope of encryption on FS01 and LMS01.

1.4 Priority Investigation Questions

1. Did the payroll attachment execute malicious code on FIN-PC07, and what process tree resulted?

Additional evidence: Full disk image or volatile memory capture of FIN-PC07; Windows Event Logs (Security, Sysmon if present); EDR telemetry for process creation and network connections.

Findings that would change assessment: Confirmed malware execution with command-and-control activity would reinforce Critical severity and expand the timeline of compromise. Absence of execution would lower confidence in initial access via the attachment and prompt re-evaluation of the cloud sign-in (E02).

2. Was the 1.2 GB HTTPS upload (E04) exfiltration of learner or staff personal data?

Additional evidence: Proxy or firewall logs with destination IP/domain reputation; file-system timeline on FIN-PC07 showing which directories were accessed immediately before the transfer; cloud-provider logs if the destination can be identified.

Findings that would change assessment: Confirmation of personal data in the transfer would trigger formal breach-assessment processes and elevate regulatory urgency. Absence of personal data would reduce confidentiality impact and focus resources on availability recovery.

3. Is the offline backup of Day -3 free from ransomware and recoverable?

Additional evidence: Controlled restoration test of a representative sample of critical examination and learner files into an isolated environment; integrity checks (hashes if previously recorded) and malware scanning of the restored data.

Findings that would change assessment: Successful clean restoration would confirm a viable recovery path and support a possible reduction from Critical to High once containment is achieved. Failure or detection of malware would force reliance on older or alternative data sources and maintain Critical severity.

Task 1 Summary

The incident is classified as ransomware with potential credential compromise and possible data staging. Initial severity is assessed as Critical on the basis of the imminent examination deadline, confirmed encryption of shared folders on FS01, dependency of the learning portal on those folders, anomalous privileged activity on the backup systems, and incomplete visibility of scope and recoverability. A structured timeline of evidence E01-E08 distinguishes confirmed observations from working hypotheses and unresolved questions, and records two plausible alternative explanations for each ambiguous event. Confirmed and potentially affected assets are evaluated under the confidentiality, integrity and availability triad. Response priorities are ordered to protect the examination window while securing privileged accounts and preserving the last offline backup. Three priority investigation questions are defined, each linked to the specific additional log, artefact or validation check required and to the findings that would alter the severity or scope assessment. All decisions cite the supplied evidence identifiers and explicitly label assumptions.

Task 2 - Incident Response Plan and Team Responsibilities.

2.1 Incident Response Policy and Plan Outline

Mission

To detect, contain, eradicate and recover from cybersecurity incidents affecting Northbridge Skills Institute in a manner that minimises operational disruption to teaching and examination services, protects the confidentiality and integrity of learner and staff data, preserves forensic evidence, and enables rapid, validated restoration of critical systems.

Objectives

I. Limit the blast radius of any confirmed or suspected incident through timely containment.
II. Maintain forensic integrity of evidence sufficient to support investigation, legal assessment and regulatory reporting.
III. Restore critical teaching and examination capability within agreed recovery time objectives while ensuring data integrity and freedom from residual malware.
IV. Deliver accurate, approved and timely communication to all relevant internal and external stakeholders.
V. Capture lessons learned and feed them into continuous improvement of technical controls, processes and the business continuity framework.

Scope

The plan covers all information systems, accounts, networks and data under the control or processing of Northbridge Skills Institute. This includes, but is not limited to, FIN-PC07, FS01, LMS01, BAK01, Microsoft 365 identity and email services, endpoints protected by EDR, and any connected cloud or third-party resources that process Institute data. The plan applies to ransomware, malware execution, credential compromise, unauthorised data transfer, and any related security events that meet the severity criteria defined in Task 1.

Incident Declaration Criteria

An incident is formally declared when one or more of the following conditions is observed:

I. Confirmed or highly probable unauthorised encryption, modification or destruction of production data or systems.
II. Confirmed or highly probable compromise of privileged accounts (including service accounts such as svc_backup) or systems that store or process personal data.
III. Material degradation or loss of availability of teaching, assessment or examination services.
IV. Any event that meets the Critical or High severity definitions established in the Institute's severity matrix.

Declaration authority rests with the Incident Response Lead. In the Lead's absence, the most senior available member of the IT or security team may declare. Declaration is recorded immediately with date, time (WAT), evidence identifiers, initial severity rating and the name of the declaring individual.

Activation Rules

Upon declaration the Incident Response Lead activates the core CSIRT via the pre-agreed secure out-of-band channel. Activation includes:

I. Notification of all core role holders.
II. Opening of the contemporaneous incident log.
III. Immediate assessment of the need for system isolation.
IV. Confirmation of the current status of the offline backup and the accessibility of the incident contact list.

Escalation Rules

Escalation is mandatory under the following conditions:

I. Any incident rated Critical.
II. Any incident that threatens the scheduled examination or other time-critical teaching activities.
III. Any confirmed or suspected exposure of personal data.
IV. Situations in which internal technical or forensic capacity is insufficient.

Escalation path:

I. Incident Response Lead ; Director of Operations (or designated senior management).
II. Director of Operations ; external forensic provider, retained legal counsel, or cyber-insurance panel as required.
III. Parallel notification to the Legal/Privacy Adviser whenever personal-data exposure is possible.

All escalations are time-stamped in the incident log.

Authority to Isolate Systems

Standing authority to isolate endpoints, servers, network segments or cloud accounts is granted to the Incident Response Lead and the designated IT Operations representative when continued connectivity presents an immediate risk of further encryption, lateral movement or data loss. Isolation of systems that directly support examinations or learner assessment requires concurrent notification to the Business Owner. Isolation actions that may cause significant operational impact are documented with systems affected, rationale, expected operational consequence, time of isolation, and name of the authorising individual. Where immediate isolation is necessary to prevent irreversible harm, the action may be taken first and the Business Owner notified immediately thereafter.

Documentation Requirements

A single incident log is maintained throughout the response. Entries record date and time (WAT), actor, evidence identifier (where applicable), decision or action taken, rationale, and outcome or next step. Evidence items must be recorded in a separate evidence register that tracks collection method, collector, integrity verification, storage location and custody transfers. Documentation is retained for a minimum of three years, or longer if required by legal, regulatory or insurance obligations. All documentation is stored in a location independent of systems that may be compromised during the incident.

Plan Review and Continuous Improvement

The plan is reviewed after every Critical or High severity incident, after any material change to systems, organizational structure or regulatory requirements, and at least once every twelve months. Reviews are led by the Incident Response Lead, involve the core CSIRT, and are approved by the Director of Operations. Lessons learned are formally recorded and tracked to closure. Improvements are reflected both in the incident response plan and in the Institute's business continuity arrangements.

Integration with Business Continuity

This incident response plan is explicitly aligned with the Institute's business continuity framework. Recovery time and recovery point objectives for LMS01 and examination-related data are taken directly from the business continuity priorities. Containment and restoration sequencing prioritises the protection and recovery of time-critical teaching and examination processes. The Business Owner retains final operational acceptance authority for the return-to-service of any system that supports examinations or learner assessment. Post-incident reviews examine both cybersecurity effectiveness and the adequacy of continuity arrangements, ensuring that technical and operational resilience improve together. This integration follows the guidance in NIST SP 800-61 Revision 3 that incident response must be embedded within broader cybersecurity risk management and organisational resilience activities, and is consistent with the CISA #StopRansomware emphasis on aligning technical response with business priorities (NIST, 2025; CISA, n.d.).

2.2 Computer Security Incident Response Team (CSIRT) Structure

Given the Institute's limited internal capacity (three IT staff plus one security analyst), the CSIRT is structured as a lean core team that can be rapidly augmented through pre-arranged external support.

Role	Primary Responsibilities	Key Focus
Incident Response Lead	Overall coordination, severity rating, escalation decisions, authority on isolation, maintenance of the incident log, final technical readiness sign-off.	Decision-making, coordination, plan ownership.
Security Analyst	Detection triage, log and EDR analysis, initial scoping, threat identification, monitoring for residual activity.	Log analysis, endpoint detection, scope determination.
Forensic Examiner	Evidence identification, collection, preservation, chain-of-custody management, timeline reconstruction.	Digital forensics, evidence integrity.
IT Operations / Systems Administrator	Technical isolation, credential reset or account disablement, network controls, backup validation support, execution of approved restoration steps.	Systems and network administration, Microsoft 365, backup platforms.
Business Owner (Academic or Operations)	Assessment of impact on examinations and teaching, prioritisation of recovery sequence, final operational acceptance of restored services.	Teaching schedules, examination processes, learner impact.
Legal / Privacy Adviser	Assessment of personal-data exposure, determination of notification obligations and deadlines, review of formal notices.	Data-protection requirements, breach assessment.
Communications Lead	Drafting and distribution of approved messages, management of the communication matrix, operation of secure alternative channels, media handling if required.	Stakeholder messaging, crisis communication.

Obtaining additional support:
When core capacity or specialised expertise is exceeded, the Incident Response Lead is authorised to engage pre-arranged external resources: contracted forensic or incident-response provider for deep analysis, malware examination or large-scale evidence processing; external legal counsel specialising in data protection if the retained adviser is unavailable; Microsoft or cloud-service support channels for tenant-level identity actions; and the cyber-insurance incident-response panel where the policy provides access. Contact details for these external parties form part of the resilient incident contact list. Engagement is logged and any statements of work or contracts are retained for audit.

2.3 RACI Matrix

R = Responsible (performs the work); A = Accountable (exactly one final decision authority per activity; combined A/R is permitted where explicitly stated); C = Consulted (provides input before action); I = Informed (kept updated after action).

Activity	IR Lead	Sec Analyst	Forensic	IT Ops	Bus Owner	Legal	Comms
Detection	A	R	I	C	I	I	I
Analysis	A	R	C	C	I	C	I
Containment	A/R	C	C	R	C	I	I
Evidence handling	A	C	R	C	I	C	I
Stakeholder communication	A	I	I	I	C	C	R
Assessment of reporting obligations	A	C	C	I	I	R	C
Restoration approval	A	C	C	R	A/R	C	I
Closure or review	A	R	R	C	C	C	R

Note: Restoration approval carries joint accountability. The Incident Response Lead confirms technical readiness and freedom from residual compromise; the Business Owner confirms operational acceptance for teaching and examination use.

2.4 Preparation Improvements and Readiness Checklist

Four priority improvements address the specific gaps exposed by the current incident (untested network backups, contact list stored only on FS01, reliance on potentially compromised email, and limited internal forensic depth).

Improvement	Owner	Resources Required	Readiness Verification & Target
1. Backup readiness and immutability	IT Operations (oversight by Incident Response Lead)	Immutable or air-gapped backup capability; documented restoration procedures; isolated test environment; staff time for testing.	Successful restoration of a representative set of critical examination and learner files into an isolated environment. First test within 30 days; thereafter quarterly. Documented recovery time and recovery point achieved; Business Owner sign-off.
2. Accessible and resilient incident contact list	Communications Lead (supported by IT Operations)	Printed hard-copy and offline encrypted digital copies stored outside FS01 and corporate email; inclusion of external forensic, legal, insurer and cloud-support contacts; version-control process.	Physical and offline digital copies confirmed present and current at the start of each academic term and after any staff change. Random verification that at least two core CSIRT members can retrieve the list without network access.
3. Secure out-of-band communication channel	Communications Lead and Incident Response Lead	Encrypted messaging platform or dedicated secure conference bridge independent of Microsoft 365 and corporate email; pre-shared access credentials stored offline.	Quarterly functional test involving all core CSIRT members. Confirmation that messages can be sent and received under the assumption that corporate email is compromised.
4. Structured training and tabletop programme	Incident Response Lead	Annual tabletop exercise schedule; short technical playbooks for isolation and evidence collection; access to external training or retained forensic provider for skill maintenance.	At least one full tabletop exercise completed each year with documented decision log and tracked improvement actions. Individual CSIRT members complete role-relevant technical refresher training within 90 days of assignment and annually thereafter.

These improvements are measurable, owned, and directly responsive to the weaknesses identified in the scenario evidence. They also align with the preparation emphasis in NIST SP 800-61 Revision 3 and the practical readiness recommendations in the CISA #StopRansomware Guide (NIST, 2025; CISA, n.d.).

Task 3 - Response Playbook and Evidence Preservation.

3.1 Response Playbook - First 60 Minutes and Remainder of First 24 Hours

The playbook below is ordered chronologically and covers short-term containment, investigation, longer-term containment, eradication, recovery preparation, and closure activities. It addresses the affected endpoints (FIN-PC07), privileged and cloud accounts, the shared server (FS01), the learning portal (LMS01), the suspicious outbound transfer, and backup access (BAK01 and the offline backup). All times are West Africa Time (WAT). The Incident Response Lead retains overall coordination authority throughout.

Playbook - First 60 Minutes (08:45 - 09:45)

Time / Stage	Action	Owner	Required Approval	Evidence to Retain	Completion Check
08:45 - 08:50 Immediate activation	Declare the incident Critical. Activate core CSIRT via secure out-of-band channel. Open contemporaneous incident log. Confirm accessibility of offline contact list.	Incident Response Lead	None (standing authority)	Declaration record, activation log entry	Log opened; all core members notified and acknowledged
08:50 - 09:00 Short-term containment - endpoint	Isolate FIN-PC07 from the network (disable switch port or apply host-based isolation). Do not power off. Preserve volatile memory if feasible.	IT Operations	Incident Response Lead	Network isolation timestamp, switch-port log, any memory capture notes	FIN-PC07 confirmed offline from production network; memory capture status recorded
09:00 - 09:10 Short-term containment - privileged accounts	Disable or force password reset and session revocation for the finance officer account and svc_backup account in Microsoft 365 and on-premises directories. Revoke active refresh tokens.	IT Operations / Security Analyst	Incident Response Lead	Account disablement logs, Microsoft 365 audit export for the accounts	Accounts confirmed disabled or credentials rotated; sessions revoked

09:10 - 09:20 Short-term containment - shared server and backups	Restrict further administrative access to FS01 and BAK01. Block outbound traffic from FS01 and BAK01 to external destinations. Confirm the offline (Day -3) backup remains disconnected and physically secured.	IT Operations	Incident Response Lead	Access-control change logs, firewall rule changes, offline backup location confirmation	FS01 and BAK01 administrative access limited; offline backup confirmed isolated
09:20 - 09:30 Initial investigation - scope	Collect initial EDR alerts, Windows Security and System event logs from FIN-PC07 (if still accessible), and Microsoft 365 audit logs for the finance officer and svc_backup accounts. Identify any additional systems showing similar encryption indicators.	Security Analyst	None	Log exports, EDR alert summaries	Initial log set exported and stored in evidence location
09:30 - 09:40 Investigation - suspicious transfer	Retrieve full proxy or firewall logs for the 1.2 GB HTTPS upload from FIN-PC07 (E04). Record destination IP, domain, timestamp and volume. Begin reputation checks on the destination.	Security Analyst	None	Proxy/firewall log extract, destination reputation notes	Destination details recorded; reputation check initiated
09:40 - 09:45 Communication and escalation	Notify Director of Operations of Critical status, examination impact, and isolation actions taken. Confirm secure communication channel remains available.	Incident Response Lead / Communications Lead	Incident Response Lead	Notification record, acknowledgement	Senior management notified; channel status confirmed

Playbook - Remainder of First 24 Hours (09:45 Day 0 to 08:45 Day +1)

Time / Stage	Action	Owner	Required Approval	Evidence to Retain	Completion Check
09:45 - 11:00 Investigation and longer-term containment	Expand log collection to FS01 and LMS01 (where accessible). Search for additional indicators of compromise (new accounts, scheduled tasks, unusual services, persistence mechanisms). Identify any further systems showing .locked files or ransom notes.	Security Analyst / Forensic Examiner	Incident Response Lead	Expanded log set, IOC list, additional system inventory	Broader compromise assessment documented; additional affected systems listed
10:00 - 12:00 Evidence preservation	Begin formal imaging of FIN-PC07 (disk and any remaining volatile memory). Capture relevant logs from FS01 and BAK01 before further changes. Document all collection steps.	Forensic Examiner	Incident Response Lead	Imaging logs, chain-of-custody forms, collection notes	Images and logs collected or collection in progress; custody forms initiated
11:00 - 13:00 Examination contingency	Assess whether a limited, clean subset of examination materials can be restored from the offline backup into an isolated environment or delivered by alternative means. Coordinate with Business Owner on operational feasibility.	IT Operations / Business Owner	Business Owner (operational) + Incident Response Lead (technical)	Restoration test notes, Business Owner decision record	Contingency decision recorded; any limited restoration performed under controlled conditions
13:00 - 16:00 Longer-term containment and persistence search	Continue search for persistence mechanisms on all identified systems (run keys, scheduled tasks, services, WMI subscriptions, cloud app consents). Remove or disable confirmed persistence only after evidence collection.	Security Analyst / Forensic Examiner	Incident Response Lead	Persistence inventory, removal actions log	Persistence items identified and documented; removal actions logged
16:00 - 20:00 Eradication preparation	Confirm removal of malware from FIN-PC07 and any other confirmed infected endpoints.	Security Analyst / IT Operations	Incident Response Lead	Eradication checklist, credential rotation	Confirmed malware removed from known systems; credentials secured

	Validate that privileged credentials have been rotated and that no unauthorised cloud applications remain consented.			confirmation	
20:00 - 08:00 (overnight) Recovery preparation	Select the offline (Day -3) backup as the primary recovery source. Prepare an isolated recovery environment. Begin validation of a representative sample of critical examination and learner files.	IT Operations / Forensic Examiner	Incident Response Lead	Backup selection rationale, validation test results	Offline backup selected; sample validation initiated
By 08:45 Day +1 Closure of first 24 hours	Compile status report covering containment status, evidence collected, broader compromise findings, examination contingency outcome, and recommended next steps for full recovery. Update senior management.	Incident Response Lead / Communications Lead	Incident Response Lead	24-hour status report	Status report completed and distributed

Checking for broader compromise:
Throughout the first 24 hours the Security Analyst and Forensic Examiner continuously expand the search for indicators of compromise beyond the initially identified systems. This includes review of authentication logs for additional unusual sign-ins; examination of FS01 and BAK01 for new or modified administrative accounts, scheduled tasks, or unexpected network connections; correlation of EDR telemetry across all covered endpoints; and review of Microsoft 365 audit logs for consent grants, mailbox forwarding rules, or unusual application activity. Any newly identified system is immediately assessed for isolation and evidence collection.

3.2 Justification of Two Difficult Decisions

Decision 1 - Containment while preserving useful evidence

Immediate network isolation of FIN-PC07 was ordered at approximately 08:50. Powering the system off was deliberately avoided in order to preserve volatile memory that may contain encryption keys, process trees, or network connections. Isolation at the network level prevents further command-and-control communication and stops additional encryption or data transfer while still allowing forensic acquisition of memory and disk. Immediate isolation is necessary when continued connectivity presents a clear risk of further encryption of shared resources, lateral movement using privileged credentials, or additional data staging. In this case the combination of confirmed .locked files on FS01, anomalous svc_backup activity, and the prior large outbound transfer met that threshold. Any evidence loss (for example, loss of volatile memory if the system had already been rebooted, or loss of network connections after isolation) is documented in the incident log with the time of isolation, the systems affected, the rationale, and the residual investigative value of the remaining artefacts. Operational impact of isolation (loss of the finance workstation) is also recorded so that business owners understand the trade-off.

Decision 2 - Restoring examination access while backup safety remains uncertain

The examination for 100 learners is scheduled for 11:00. Full restoration from the offline backup cannot be completed and validated in the remaining time, and the network backups remain untrusted. Therefore a limited contingency was authorised: assessment of whether a clean subset of examination materials can be restored into an isolated environment or delivered by alternative controlled means. This decision balances the educational obligation to the learners against the risk of introducing residual malware or incomplete data into the production environment. Full production restoration is deferred until the offline backup has been validated in a controlled environment. Any limited restoration performed is treated as a temporary, isolated measure and is fully documented, including the data sources used, the validation steps performed, and the residual risk accepted by the Business Owner.

3.3 Evidence Register (Minimum Four Items)

Access to all evidence is restricted to the Forensic Examiner, the Incident Response Lead, and any external forensic provider under contract. Evidence is stored on encrypted media or in an access-controlled evidence

repository that is independent of FS01 and BAK01. Custody transfers are recorded on the register and require dual acknowledgement.

ID	Source	Proposed Collection Method	Collector	Date & Time (WAT)	Integrity Check	Secure Storage	Custody Transfers
EV-01	FIN-PC07 (endpoint)	Full disk image and volatile memory capture (if system still powered) using write-blocked or forensic imaging tools	Forensic Examiner	Planned - collection to commence after isolation, target start 09:30 Day 0	Planned: cryptographic hash (SHA-256) of image files to be calculated immediately after acquisition and recorded	Encrypted external media stored in access-controlled evidence safe; offline from production network	Initial custody: Forensic Examiner. Any transfer to external provider or Legal Adviser to be logged with date, time, recipient and purpose
EV-02	Microsoft 365 audit logs (finance officer and svc_backup accounts)	Export of relevant audit records via Microsoft 365 compliance portal or PowerShell for the period Day -1 16:00 to Day 0 09:00	Security Analyst	Planned - export target 09:20-09:40 Day 0	Planned: hash of exported log files; retention of original export package	Encrypted storage in evidence repository; access limited to CSIRT core	Initial custody: Security Analyst. Transfer to Forensic Examiner for correlation logged
EV-03	Proxy / firewall logs of 1.2 GB HTTPS upload (E04)	Extraction of relevant connection records (source, destination, volume, timestamp, protocol) from proxy or firewall logging system	Security Analyst	Planned - extraction target 09:30-09:45 Day 0	Planned: hash of extracted log set	Encrypted evidence repository	Initial custody: Security Analyst. Transfer to Forensic Examiner logged if deeper analysis required
EV-04	Offline backup set (Day -3, 17:00)	Physical securing of the offline backup media; later selective restoration of representative critical files into an isolated validation environment for integrity and malware checking	IT Operations / Forensic Examiner	Physical securing: immediate (Day 0 09:15). Validation restoration: planned overnight Day 0 / early Day +1	Planned: comparison of restored file hashes (where original hashes exist) and full malware scan of restored sample	Offline backup media remains air-gapped; restored sample held in isolated recovery environment only	Custody of media: IT Operations. Custody of restored sample: Forensic Examiner. Any movement logged

Additional evidence items (FS01 logs, LMS01 logs, further endpoint images) will be added to the register as they are identified and collected. No cryptographic hashes are claimed until actual acquisition has occurred.

3.4 Eradication, Credential Security, Restoration Order and Recovery Acceptance Criteria.

Removal of persistence and addressing the likely entry point

Persistence mechanisms identified during investigation (run keys, scheduled tasks, services, WMI event subscriptions, malicious cloud application consents, or unauthorised local accounts) are removed only after forensic acquisition is complete. The likely initial entry point-the unexpected payroll attachment opened on FIN-PC07-is addressed by full forensic examination of FIN-PC07, confirmation that the malicious attachment and any dropped payloads are removed, review of mail filtering and attachment handling rules to prevent recurrence, and user awareness reinforcement for the finance team.

Securing compromised credentials

All credentials associated with the finance officer account and the svc_backup account are treated as compromised. Actions include forced password reset or account disablement, revocation of all active sessions and refresh tokens in Microsoft 365, review and removal of any mailbox forwarding rules or application consents granted by these accounts, rotation of any service account passwords or keys that may have been accessible from the compromised systems, and enforcement of phishing-resistant multi-factor authentication where not already in place.

Recommended restoration order

I. Offline backup media itself (confirm integrity and freedom from compromise).
II. Critical examination materials and associated learner assessment files required for the immediate examination contingency.
III. Core FS01 shares that support LMS01 functionality.
IV. Remaining FS01 data in order of business criticality.
V. FIN-PC07 (re-imaged from clean media after full forensic examination).
VI. Any other affected endpoints.

Recovery targets and acceptable data loss

Recovery Time Objective (RTO) for examination-critical materials: restore sufficient clean materials to support the examination process within the shortest feasible window, accepting that full production restoration of all systems will take longer. Recovery Point Objective (RPO): acceptance of data loss back to the last known-good offline backup (Day-3, 17:00). Any data created or modified between that point and the incident is treated as potentially lost or untrusted until alternative sources can be validated. Acceptable data loss is therefore defined as all changes after 17:00 on Day -3, unless clean alternative copies can be located and validated.

Backup selection, validation and controlled restoration

The offline backup from Day -3 is selected as the primary recovery source because network backups are not immutable and show anomalous administrative activity. Validation proceeds as follows: (1) confirm physical custody and air-gapped status of the offline media; (2) restore a representative sample of critical examination and learner files into a fully isolated recovery environment that has no connectivity to production systems; (3) perform malware scanning and, where original hashes exist, cryptographic integrity verification of the restored sample; (4) review restored data for completeness and usability with the Business Owner; (5) only after successful validation is a controlled restoration into a staging environment authorised; (6) continuous monitoring for recurrence (new encryption activity, unexpected processes, anomalous authentication) is maintained for a defined observation period before the Business Owner is asked to approve return to production service.

Recovery acceptance criteria (Business Owner approval gate)

Return of any restored service to production use requires explicit Business Owner approval based on the following criteria: technical confirmation by the Incident Response Lead and IT Operations that the restored data originates from a validated clean backup; confirmation that malware scanning and integrity checks on the restored data have completed with no residual indicators of compromise; confirmation that privileged credentials have been rotated and that monitoring for recurrence is active; documented residual risk statement (including the accepted data-loss window) signed by the Incident Response Lead; and operational acceptance by the Business Owner that the restored materials are sufficient and safe for teaching or examination use. Only when all of the above conditions are met is production service authorised to resume.

Task 4 - Communication and Escalation.

4.1 Communication Matrix

The matrix below covers at least six stakeholder groups and includes an alternative channel for use when corporate email or Microsoft 365 is considered unsafe or unavailable. All messages are logged in the incident record with time, recipient group, channel used, and approver.

Stakeholder Group	Trigger	Message Owner	Primary Channel	Alternative Channel	Approver	Update Frequency
Senior Management / Director of Operations	Incident declaration (Critical); any change in severity; decisions requiring resource or operational approval;	Incident Response Lead	Secure out-of-band channel or direct telephone	Encrypted messaging application or pre-agreed secure conference bridge	Incident Response Lead (content); Director of Operations (acknowledgement)	Immediate on declaration; thereafter every 2 hours during active response or on material change

	examination impact					
IT and Security Staff (including core CSIRT)	Activation; containment actions; evidence collection requirements; technical status changes	Incident Response Lead / Security Analyst	Secure out-of-band channel	Encrypted messaging application or dedicated secure bridge	Incident Response Lead	Continuous during first 60 minutes; thereafter hourly or on significant technical change
Learners (affected cohort of 100 plus wider learner body as needed)	Confirmed impact on portal access or examination; any change to examination arrangements	Communications Lead	Official learner portal notice (if available) or SMS / telephone cascade via academic staff	Pre-recorded telephone message or SMS via academic coordinators using staff mobile phones; printed notices if required	Business Owner (content accuracy); Communications Lead (distribution)	Initial notice as soon as examination status is decided; update at least 1 hour before any scheduled examination start time; further updates on material change
Legal / Privacy Adviser	Any indication of personal-data exposure; request for formal breach assessment; draft external notices	Incident Response Lead	Secure out-of-band channel or direct telephone	Encrypted messaging or secure file-transfer method	Incident Response Lead	Immediate on first indication of possible personal-data involvement; thereafter as assessment progresses
Relevant Service Provider (Microsoft 365 / identity support or contracted forensic provider)	Need for tenant-level identity actions, log access, or external forensic support	IT Operations / Incident Response Lead	Official support portal or pre-arranged emergency contact	Telephone to pre-registered emergency support number; secure upload portal provided by the vendor	Incident Response Lead	As required by the technical need; status check at least once every 4 hours while support is active
Academic / Examination Coordinators (Business Owner representatives)	Examination contingency decisions; restoration status of learning materials; learner communication content	Communications Lead / Business Owner	Secure out-of-band channel or direct telephone	Encrypted messaging or staff mobile cascade	Business Owner	Immediate when examination impact is confirmed; thereafter aligned with examination timeline and restoration milestones

Escalation Rules Table

Escalation Condition	Escalation From	Escalation To	Time Requirement	Authority / Notes	Record Keeping
Incident declared Critical	Incident Response Lead	Director of Operations (Senior Management)	Immediate (within 15 minutes of declaration)	Mandatory	Time, method, and acknowledgement recorded in incident log
Any change in severity rating (upward or downward)	Incident Response Lead	Director of Operations	Within 30 minutes of the change	Mandatory	Updated severity and rationale logged
Examination schedule or learner access materially affected	Incident Response Lead / Business Owner	Director of Operations	Immediate	Mandatory before any public or learner-facing decision	Decision and approval recorded
Confirmed or reasonably suspected personal-data exposure	Incident Response Lead	Legal / Privacy Adviser (and parallel notification to Director of Operations)	Immediate	Mandatory; no formal external notification without Legal review	Evidence summary supplied; Legal recommendation logged
Internal technical or forensic capacity exceeded	Incident Response Lead	External forensic provider and/or cyber-insurance	As soon as capacity limit is recognised	Authorised by Incident Response Lead; Director of	Engagement record and scope of work retained

		panel		Operations informed	
Media, journalist, or external public enquiry received	Communications Lead	Legal / Privacy Adviser and Director of Operations	Immediate; no response issued until cleared	Mandatory prior review	Enquiry details and approved response logged
Primary communication channel assessed as compromised or unavailable	Communications Lead / Incident Response Lead	All relevant stakeholders via alternative channel	Immediate switch	Standing authority to switch channels	Channel change and reason recorded in incident log
Request for regulatory or contractual breach notification	Legal / Privacy Adviser	Director of Operations (final authorisation)	In accordance with statutory or contractual deadline	Formal notification issued only after written Legal recommendation and senior management approval	Full recommendation, deadline calculation, and authorisation retained

These escalation rules ensure that decision rights remain clear, that time-critical issues reach the appropriate authority without delay, and that every escalation is auditable.

4.2 Executive Briefing.

Subject: Critical Incident Status - Suspected Ransomware - Day 0 09:30 WAT

At 08:45 WAT a Critical incident was declared following confirmed mass file encryption on FIN-PC07 and the presence of .locked files together with a ransom note on FS01 shared folders. The learning portal remains reachable at the login page but learners cannot open materials or submit assessments. An online examination for 100 learners is scheduled for 11:00 WAT.

Confirmed impact: encryption of shared folders on FS01; isolation of FIN-PC07; anomalous privileged activity by the svc_backup account; and a prior 1.2 GB outbound transfer from FIN-PC07 whose content remains unknown.

Uncertainty: malware family unconfirmed; recoverability of the offline backup (Day -3) not yet validated; extent of personal-data exposure unknown; trustworthiness of corporate email unverified.

Decisions requiring your approval:

I. Authorisation of limited contingency arrangements for the 11:00 examination if full clean restoration cannot be completed in time.
II. Engagement of external forensic support if internal capacity is exceeded.
III. Any decision to notify external parties beyond operational stakeholders.

Next formal update will be provided at 11:30 WAT or immediately upon any material change in containment or examination status.

The Incident Response Lead, Northbridge Skills Institute

4.3 Learner Notice.

Important Notice - Learning Portal and Examination Arrangements

We are currently responding to a technical incident that has affected access to some learning materials on the portal. The login page remains available, but opening of materials and submission of assessments is temporarily disrupted.

The online examination scheduled for 11:00 today is under active review. We are working to provide alternative arrangements so that no learner is disadvantaged. Please check your registered mobile number and the official notice channels for an update no later than 10:30. Do not attempt to submit assessments through the portal until further notice.

If you have an urgent examination-related query, contact your course coordinator by telephone using the numbers previously supplied. We apologise for the disruption and will provide a further update as soon as the position is confirmed. - Academic Operations, Northbridge Skills Institute

4.4 Assessment of Notification Obligations by Legal / Privacy Advisers.

The Legal / Privacy Adviser is responsible for determining whether the incident constitutes a notifiable personal-data breach and, if so, identifying the correct recipients and statutory deadlines.

Assessment process:

I. The Incident Response Lead supplies the Legal / Privacy Adviser with the current evidence pack, the timeline, the list of potentially affected data categories (learner contact details, admission documents, assessment records, finance files), and the status of the 1.2 GB outbound transfer.
II. The Adviser evaluates whether personal data has been, or is reasonably likely to have been, accessed, copied, transmitted, or rendered unavailable in a manner that compromises confidentiality, integrity or availability.
III. The Adviser distinguishes clearly between operational notices (internal management updates, learner service messages, and technical communications with service providers) which may be issued under the authority of the Incident Response Lead and Business Owner, and formal breach notifications (regulatory notifications, notifications to affected individuals, and any notifications required under contractual obligations) which may be issued only after Legal / Privacy Adviser review and senior management authorisation.
IV. The Adviser confirms the relevant jurisdiction. For an education and training provider operating in West Africa, the primary data-protection framework is the applicable national data-protection law (for example, the Nigeria Data Protection Act 2023 if the Institute is subject to Nigerian jurisdiction, or the equivalent legislation of the relevant West African state). Where the Institute processes data of individuals in other jurisdictions, additional regimes are also assessed.
V. Statutory deadlines are confirmed by reference to the authoritative legal text. Under the Nigeria Data Protection Act 2023, for example, a personal-data breach that is likely to result in a risk to the rights and freedoms of individuals must be notified to the Nigeria Data Protection Commission without undue delay and, where feasible, within 72 hours of becoming aware of the breach. The Adviser records the precise statutory reference and the calculated deadline in the incident log.
VI. The Adviser also identifies any contractual notification obligations to partners, insurers or funding bodies and the associated timelines.
VII. A written recommendation is provided to the Incident Response Lead and senior management stating: (a) whether formal notification is required; (b) the recipients; (c) the deadline; and (d) the minimum content required. No formal external breach notification is issued without this written recommendation and senior management authorisation. Operational notices to learners and staff continue in parallel under the communication matrix and do not constitute formal breach notification.

Task 5 - Tabletop Exercise and Improvement Plan.

5.1 Exercise Design

Exercise Title: Northbridge Skills Institute - Ransomware Tabletop Exercise (Critical Incident Simulation)

Duration: 60 minutes

Objectives:

1. Test the ability of the CSIRT to apply the incident response plan under time pressure, particularly the examination deadline and uncertain backup status.
2. Validate decision rights for containment, restoration approval, and external communication.
3. Rehearse escalation to senior management and Legal/Privacy Adviser when personal-data exposure is alleged.
4. Identify gaps in backup validation, secure communication, and media handling.
5. Produce a documented decision log and a prioritised improvement plan.

Participant Roles (played sequentially by the exercise facilitator in this individual walkthrough): Incident Response Lead; Security Analyst; Forensic Examiner; IT Operations; Business Owner; Legal / Privacy Adviser; Communications Lead; Director of Operations (Management).

Agenda:

Time	Activity
00-05 min	Exercise briefing, role confirmation, and restatement of current incident status (as at 08:45 Day 0)
05-10 min	Free-play period - initial containment and communication actions
10 min	Inject 1
10-20 min	Response to Inject 1
20 min	Inject 2
20-35 min	Response to Inject 2
35 min	Inject 3
35-45 min	Response to Inject 3
45 min	Inject 4
45-55 min	Response to Inject 4 + additional Inject 5
55-60 min	Hot wash, success-criteria evaluation, and capture of immediate lessons

Measurable Success Criteria:

I. At least 80 % of the decisions recorded in the decision log cite a specific plan section, evidence identifier, or pre-defined authority.
II. No restoration of production systems is authorized without documented validation of the backup source or explicit Business Owner acceptance of residual risk.
III. All external or learner-facing communications are reviewed by the appropriate approver (Business Owner or Legal/Privacy Adviser) before release.
IV. The offline backup remains protected and is prioritized over unverified network backups throughout the exercise.
V. A prioritized improvement list with owners and target dates is produced before the end of the 60-minute session.

5.2 Simulated Walk-through and Decision Log.

All results below are labeled as simulation only.

Inject 1 - Minute 10: Management asks the team to reopen the learning portal before the 11:00 examination, even if the most recent backup is unverified.

Inject 2 - Minute 20: An attacker claims to hold all 1,800 learner records and threatens publication in 12 hours. A screenshot is provided; authenticity is unknown.

Inject 3 - Minute 35: A test restoration of the latest network backup fails with an unreadable snapshot error.

Inject 4 - Minute 45: A social media post claims the examination is canceled. A journalist asks whether learner information has been exposed.

Additional Inject 5 - Minute 50 (own inject): The finance officer whose account was used in the initial access telephones the help-desk in a distressed state, stating that they have received a direct message from the attacker demanding payment and threatening to name them publicly as the person who “opened the door”.

Decision Log (Simulation)

Inject	Decision	Decision Owner	Rationale	Communication	Effect on Response / Recovery Plan
1 (Min 10)	Refuse immediate full reopening of the production learning portal. Authorise only a limited, isolated contingency for examination materials if a clean subset can be validated in time.	Incident Response Lead + Business Owner	Plan requires validated backup or explicit residual-risk acceptance before production restoration. Unverified backup presents unacceptable risk of reinfection or incomplete data.	Secure channel message to Director of Operations explaining the decision and the contingency option.	Recovery plan remains focused on the offline (Day -3) backup. Production portal stays isolated. Examination contingency planning accelerated.
2 (Min 20)	Treat the claim as unconfirmed. Do not engage the attacker.	Incident Response Lead	Authenticity unknown; engagement risks further compromise or	Secure notification to Legal/Privacy Adviser and Director	Formal breach-assessment process initiated. Evidence register updated with the screenshot (EV-05). No

	Escalate immediately to Legal/Privacy Adviser for breach-assessment advice. Preserve the screenshot as potential evidence.		legal exposure. Personal-data claim triggers mandatory Legal review.	of Operations. No public or learner statement about data exposure.	change to technical containment.
3 (Min 35)	Abandon reliance on the latest network backup. Confirm the offline Day -3 backup as the sole primary recovery source and accelerate its validation in an isolated environment.	Incident Response Lead + IT Operations	Network backup has failed integrity check and is consistent with possible compromise of BAK01. Offline backup remains the only known-good source.	Status update to Director of Operations and Business Owner.	Recovery plan formally switches to offline backup only. Network backup marked untrusted. Validation resources concentrated on Day -3 media.
4 (Min 45)	Issue no immediate public response to the social-media claim or journalist. Route the journalist enquiry to Communications Lead for holding statement only after Legal and senior management review. Prepare factual internal update for academic staff.	Communications Lead + Legal/Privacy Adviser	Unverified social-media claims and media enquiries require controlled handling to avoid inaccurate statements or premature admission of data exposure.	Holding line approved by Legal: "We are aware of reports and are investigating. We will provide accurate information through official channels."	Media-handling protocol activated. No change to technical recovery sequence. Learner notice remains focused on service status only.
5 (Min 50)	Instruct helpdesk to take no further details from the finance officer over the telephone. Arrange a secure, logged call with the Incident Response Lead and Legal Adviser. Treat the direct threat as potential evidence of continued attacker activity and possible intimidation.	Incident Response Lead + Legal/Privacy Adviser	Direct contact from the attacker may yield intelligence but also risks contamination of the witness or further social-engineering. Support for the staff member is required.	Secure internal message to helpdesk and HR support. Legal advised of possible intimidation element.	Staff-welfare action added. Evidence collection extended to any messages received by the finance officer. No technical change to containment or recovery.

5.3 Evaluation against Success Criteria (Simulation Results).

Success Criterion	Result	Observation
1. ≥ 80 % of decisions cite plan section, evidence or authority	Met	All five recorded decisions referenced either the restoration-approval rule, the Legal escalation rule, or the backup-priority rule.
2. No production restoration without validated backup or explicit residual-risk acceptance	Met	Full portal reopening was refused; only limited contingency under controlled conditions was considered.
3. External/learner-facing communications reviewed by appropriate approver	Met	Journalist response and any learner messaging required Legal or Business Owner clearance.
4. Offline backup protected and prioritised	Met	After Inject 3 the network backup was formally abandoned; offline backup became the sole recovery source.
5. Prioritised improvement list produced within the session	Met	Five improvements identified and assigned before the 60-minute mark.

5.4 Improvement Plan.

Priority	Improvement	Owner	Target Completion	Measurable Evidence of Completion
1 (Critical)	Establish and test an isolated recovery environment dedicated to backup validation	IT Operations	14 days	Successful restoration of a full critical-data sample from the offline backup into the isolated environment; documented test report signed by Incident Response Lead and Business Owner
2 (High)	Create a pre-approved media and social-media holding statement template, reviewed by Legal	Communications Lead + Legal/Privacy Adviser	21 days	Template published in the incident response plan appendix; tabletop re-test confirms it can be issued within 15 minutes of a media inject
3 (High)	Implement immutable or air-gapped backup with quarterly restoration testing	IT Operations	30 days	First successful quarterly restoration test completed and recorded; backup policy updated
4 (Medium)	Develop a staff-welfare and potential-intimidation protocol for individuals named by attackers	Incident Response Lead + HR / Legal	30 days	Written protocol added to the plan; helpdesk script updated; one awareness briefing delivered to IT and helpdesk staff
5 (Medium)	Pre-stage secure out-of-band contact details for external forensic provider and Legal counsel on the offline contact list	Communications Lead	10 days	Offline contact list updated and verified by two CSIRT members; random retrieval test passed

Post-Incident Review Deadline and Closure Authority: A formal post-exercise review will be completed within 10 working days of the tabletop. The Incident Response Lead owns the review report. All improvement actions are tracked to closure by the Incident Response Lead; final sign-off that an action is complete rests with the Director of Operations (or designated senior manager). Actions not closed by the target date are escalated automatically to the Director of Operations.

Task 6 - Case Study Analysis and Critical Reflection.

The illustrative healthcare ransomware case on slide 16 of the GRC105 teaching deck describes a hospital that experienced encryption of clinical and administrative systems, disruption to patient care, uncertainty regarding data exfiltration, and intense pressure to restore services. Three response strengths stand out. The organisation isolated affected network segments rapidly, thereby limiting further encryption of critical care systems. It possessed an offline backup that had been restoration-tested within the previous six months, providing a viable recovery path once the environment was stabilised. A pre-defined communication structure enabled clinical leadership and external partners to receive timely operational updates, reducing confusion during the acute phase.

Two limitations remain unresolved. Detection occurred only after encryption was already widespread, revealing inadequate early-warning coverage on servers and privileged accounts. In addition, the hospital could not definitively determine whether patient data had left the network; incomplete outbound-traffic logging and the absence of timely endpoint forensic images left the exfiltration question open.

Two practices transfer directly to the Northbridge plan. First, the explicit linkage between technical containment and business-continuity priorities-clinical systems received restoration precedence-reinforces the joint accountability already assigned to the Incident Response Lead and Business Owner for restoration approval. Second, the insistence on validated offline backups before production return-to-service strengthens Northbridge's current reliance on an untested Day -3 backup and non-immutable network backups.

Restoring critical systems within 72 hours differs from full restoration over seven days. The shorter window focuses on the most time-sensitive operational functions (patient care or, at Northbridge, the scheduled examination) so that essential services resume under controlled conditions with residual risk explicitly accepted. Full restoration over seven days encompasses complete data recovery, eradication of persistence, forensic closure, and sustained monitoring across the entire estate. The former prioritises availability of core services; the latter prioritises integrity and long-term assurance.

Before claiming that no patient or learner data was stolen, complete forensic images of the initially compromised systems, full outbound proxy and firewall logs, confirmation of the absence of unauthorised cloud or remote-

access sessions, and correlated authentication logs are required. Without this evidence, absence of proof of theft cannot be treated as proof of absence.

Following the tabletop exercise, one decision in the Northbridge plan is revised. The original playbook permitted limited contingency restoration of examination materials while validation was still under way. The exercise showed that even limited restoration creates pressure to expand scope prematurely. The revised rule is that no examination materials will be restored to any learner-accessible environment until a documented sample validation of the offline backup has been completed and signed off by both the Incident Response Lead and the Business Owner.

References

CISA. (n.d.). *#StopRansomware Guide*. Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/resources-tools/resources/stopransomware-guide

National Institute of Standards and Technology. (2025). *SP 800-61 Revision 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. https://csrc.nist.gov/pubs/sp/800/61/r3/final

Nigeria Data Protection Act. (2023). Federal Republic of Nigeria.

Authorship and Acknowledgement

This submission represents the independent analysis of the author applied to the supplied Northbridge Skills Institute scenario. All data and organisational details remain fictional. Sources have been acknowledged in accordance with the course policy.

Student Name: Samuel Adeoluwa Okunribido

Student ID: GCR2512878